Šepet

Varno sporočanje s šifriranjem od konca do konca

Skupina	Projektna skupina 13 — Ključarji
Člani	Tibor Koderman, Amar Mehić, Eva Vidic
Repozitoriji	https://gitlab.koderverse.com/fri-mag/rso (en repozitorij za vsako mikrostoritev)

1 Opis projekta

Pri večini aplikacij za klepet moramo ponudniku zaupati, da sporočil ne bo bral ali jih predal tretjim osebam; Telegram na primer klepetov privzeto ne šifrira od konca do konca, zahteve po dostopu oblasti do zasebnih sporočil pa so vse pogostejše. Razvili bomo aplikacijo Šepet za sporočanje ena na ena in v skupinah z oblikovanim besedilom in slikami. Vsebina se šifrira na napravi pošiljatelja s standardnim protokolom MLS (RFC 9420) in dešifrira šele na napravah prejemnikov, zato strežnik hrani in posreduje le šifrirane podatke. Sistem bomo zgradili iz sedmih mikrostoritev in ga namestili v oblak Azure (Kubernetes).

2 Varnostni model

Strežniku zaupamo dostavo, ne pa zaupnosti:

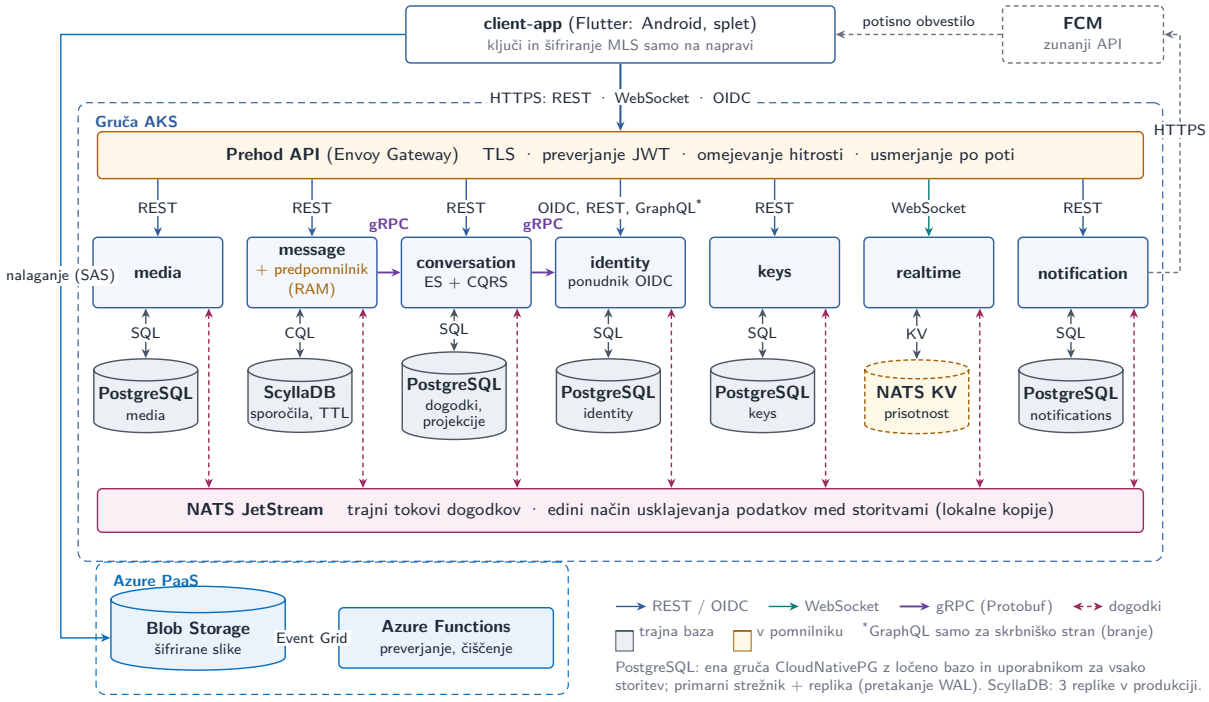
- **Vse v pogovoru je šifrirano** — sporočila, slike in imena skupin, pa tudi tipkanje, potrdila o branju in reakcije. Strežnik vidi le, kdo je v katerem pogovoru.
- **Pregleden dnevnik ključev** — javni ključi naprav so v dnevniku z Merklovim drevesom, zato strežnik zamenjave ključa ne more prikriti; uporabnika lahko primerjata tudi varnostno številko s kodo QR.
- **Prijava brez gesel** — s ključi passkey (WebAuthn).
- **Obvestila brez vsebine** — potisno obvestilo napravo le zbudi; sporočilo prenese, dešifrira in prikaže aplikacija sama.
- **Izginjajoča sporočila** — po izteku časovnika jih izbrišejo naprave in strežnik.

3 Tehnologije in razvojno okolje

Odjemalec	Flutter (Android in splet)
Šifriranje	MLS (OpenMLS), rezervna možnost Signal Protocol
Mikrostoritve	.NET 10 (ASP.NET Core), Clean Architecture
Podatkovne baze	PostgreSQL, ScyllaDB, Azure Blob Storage
Komunikacija	REST, gRPC (Protobuf), WebSocket, NATS JetStream; GraphQL samo za skrbniško stran
Identiteta	lasten ponudnik OAuth 2.0 / OpenID Connect v .NET (OpenIddict, passkeys)
Platforma	Docker, Kubernetes (Azure AKS), Helm, Envoy Gateway, Terraform
CI/CD in opazovanje	GitLab CI; Prometheus, Grafana, Loki
Drugo	Azure Functions, Firebase Cloud Messaging
Orodja	JetBrains Rider, VS Code, Android Studio, Docker Compose, kind, Git

4 Arhitektura

Aplikacija dostopa do storitev prek prehoda API, ki preverja žetone JWT in usmerja zahteve (REST, WebSocket). Kadar storitev potrebuje takojšen odgovor, kliče drugo storitev prek gRPC (npr. preverjanje članstva pri pošiljanju sporočila); dejstva, ki zanimajo več storitev, objavi kot dogodek v NATS JetStream. Vsaka storitev s trajnimi podatki ima svojo bazo, do podatkov drugih storitev pa pride le prek API-jev ali lokalnih kopij iz dogodkov; šifrirane slike potujejo neposredno v Azure Blob Storage (slika 1). Pogodbe so v repozitoriju vsake storitve: OpenAPI za REST, Protobuf za gRPC in AsyncAPI za dogodke.



Slika 1. Začetna shema arhitekture s komunikacijskimi protokoli.

5 Mikrostoritve

Storitev	Funkcionalnosti	Baza	Odgovorna oseba
identity	ponudnik OIDC: prijava s passkey, organizacije, vloge, naprave; skrbniški GraphQL (branje)	PostgreSQL	Tibor Koderman
keys	javni ključi naprav, paketi ključev MLS, pregleden dnevnik ključev	PostgreSQL	Tibor Koderman
conversation	pogovori in skupine, člani, prošnje za pogovor, časovnik izginjanja; Event Sourcing in CQRS	PostgreSQL	Amar Mehić
message	šifrirana sporočila z vrstnim redom po epohi MLS, sinhronizacija naprav, samodejno brisanje	ScyllaDB	Amar Mehić
realtime	WebSocket: dostava v živo, prisotnost, šifrirani efemerni dogodki	—	Amar Mehić
media	nalaganje in prenos šifriranih slik, omejitve velikosti	PostgreSQL	Eva Vidic
notification	potisna obvestila brez vsebine (Firebase Cloud Messaging)	PostgreSQL	Eva Vidic

Poleg tega bomo razvili aplikacijo v Flutterju in funkcijo Azure Functions, ki preveri naložene slike in briše potekle (Eva Vidic), ter skupno platformo s prehodom API, CI/CD in opazovanjem (Tibor Koderman).

6 Skaliranje

Mikrostoritve ne hranijo stanja, zato jih Kubernetes lahko poljubno podvaja, ko pride več uporabnikov:

- **HorizontalPodAutoscaler** doda pode storitvam identity, conversation, message in media, ko naraste obremenitev procesorja.
- **KEDA** skalira realtime po številu odprtih povezav WebSocket in notification po zaostanku dogodkov v NATS.
- **Samodejno skaliranje vozlišč AKS** doda vozlišče, ko novi podi nimajo prostora.
- Realtime prejema sporočila prek NATS, zato je uporabnik lahko povezan s katerimkoli podom; ScyllaDB se skalira z dodajanjem vozlišč.

Skaliranje bomo pokazali z obremenitvenim testom (k6) in metrikami v Grafani.

7 Namestitev in stroški

- **Produkcija** teče v eni majhni gruči AKS (2 vozlišči z 2 vCPU), ki jo ustavimo, ko je ne uporabljamo. Baze tečejo v gruči (CloudNativePG, ScyllaDB), slike vsebnikov so v registru GitLab, zato ne plačujemo upravljanih baz, registra ali Azure Monitor. Ocena je 15–25 USD na mesec z opozorilom proračuna pri 25 USD, kar je za ves semester manj kot kredit enega študenta.
- **Razvoj** poteka lokalno (Docker Compose, kind); cevovodi CI tečejo na našem strežniku GitLab, dodaten izvajalec CI pa na domačem strežniku. Vse ocenjevane storitve ostanejo v Azure.

8 Primeri uporabe

- registracija in prijava s ključem passkey;
- iskanje uporabnika in prošnja za pogovor, ki jo prejemnik sprejme ali zavrne;
- pošiljanje sporočil z oblikovanim besedilom in stanjem dostave (poslano, dostavljeno, prebrano);
- pošiljanje slik;
- skupine: ustvarjanje, dodajanje in odstranjevanje članov;
- obvestila, ko aplikacija ni odprta;
- preverjanje varnostne številke s kodo QR;
- izginjajoča sporočila;
- upravljanje organizacije in vlog uporabnikov (skrbnik).

Kompleksnejši primer: slika v skupinskem pogovoru

1. Aplikacija sliko šifrira z naključnim ključem in pri storitvi media dobi povezavo za nalaganje.
2. Slika se naloži v Azure Blob Storage; funkcija Azure jo preveri in obvesti media.
3. Aplikacija pošlje šifrirano sporočilo s ključem slike storitvi message, ta prek gRPC pri conversation preveri članstvo pošiljatelja.
4. message sporočilo shrani v ScyllaDB in objavi dogodek v NATS JetStream.
5. realtime ga dostavi povezanim članom, notification pa ostalim pošlje potisno obvestilo.
6. Prejemniki sporočilo in sliko dešifrirajo na svojih napravah.